PRADITA University

IT40813 · IT Governance, Risk & Compliance

Merancang Sistem Tata Kelola Target

Pertemuan 08

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Dari Celah ke Target
3. Target Kapabilitas
4. Profil Target
5. Struktur dan Forum
6. Matriks RACI
7. Kebijakan dan ITIL 4
8. Bukti, Aktivitas, dan Latihan

PRADITA University

Semua setuju arah transformasi. Siapa menyetujui apa?

Tujuan Pembelajaran

- Merancang struktur tata kelola target, termasuk forum keputusan, peran kunci, dan matriks RACI.
- Menetapkan target kapabilitas COBIT dan profil target NIST CSF yang selaras dengan *risk appetite*.
- Mengaitkan praktik ITIL 4 dengan objektif manajemen COBIT untuk menjalankan layanan TI sehari-hari.

Masalah: Semua Setuju, Keputusan Tidak Jelas

PRADITA University

- Misalkan mitra asuransi meminta integrasi untuk 6.000 klaim per bulan.
- Tim platform ingin membuka data, pemilik layanan khawatir, hukum meminta pembatasan tujuan.
- Usulan berpindah antarforum selama 4 bulan, sehingga 24.000 klaim tetap manual.
- Dua pertanyaan: siapa menyetujui pembukaan data, dan siapa memegang akuntabilitas rekam medis terpadu?
- Hasil kerja: model tata kelola target untuk tonggak C3.

Diagram Konsep Bab 8

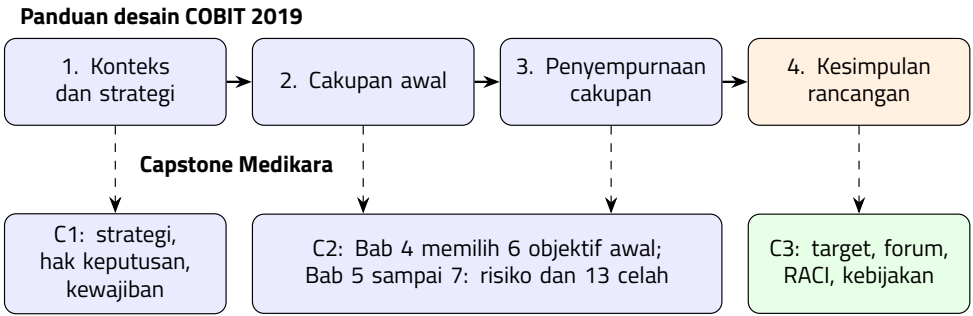
IT40813 / BAB 08 / DIAGRAM KONSEP

Rancangan tata kelola target berawal dari celah yang terbukti



Target kapabilitas dipilih sesuai kebutuhan. Kebijakan, standar, prosedur, dan pedoman memiliki fungsi serta pemilik berbeda.

Empat Tahap Panduan Desain



Bab 4 memilih enam objektif, tetapi berhenti pada kondisi saat ini. Bab ini mengerjakan tahap keempat. Bila konteks atau strategi berubah, rancangan ditinjau lagi.

Dari 13 Celah menjadi Empat Paket (Misalkan)

Paket	Celah	Risiko, kewajiban	Bukti penerimaan
A. Akses vendor	G-01, CP-01	R-01, K-01, K-05	120 dari 120 akun cocok; 60 dari 60 catatan AC-01; 11 dari 11 butir perjanjian
B. Pemulihan	G-03	R-05, K-02	144 uji per tahun; hasil disahkan pemilik layanan
C. Insiden dan pemberitahuan	G-05, CP-04	R-01, R-12, K-04, K-05	2 latihan per tahun; laporan vendor 12 jam; naskah siap sebelum jam ke-60
D. Jejak aktivitas	CP-05, G-02	R-01, R-12, K-01	Uji telusur satu rekam; 247 dari 260 tinjauan mingguan

Beban: 576 + 96 + 520 = 1.192 jam per tahun, sekitar 0,62 orang penuh waktu, atau Rp71,52 juta waktu staf. G-04, G-06, CP-02, dan CP-07 masuk gelombang kedua, sehingga R-02 tetap terbuka.

Target Bukan Tingkat Tertinggi

PRADITA University

- Tingkat 2 aktivitas dasar lengkap; tingkat 3 aset organisasi; tingkat 4 ukuran kuantitatif.
- Contoh panduan: skor 75 tingkat 4, skor 50 tingkat 3, skor 25 tingkat 2. Itu logika contoh, bukan aturan umum.
- Analogi: ambulans diperiksa harian, mobil pengantar berkas cukup servis berkala.
- Kesalahan skala: skor lokal DSS05 12 dari 15 tidak boleh diubah menjadi 80 persen lalu dibaca dengan ambang 75.
- Studi Denpasar: 5 objektif bernilai 75, tetapi 2 bertarget tingkat 3. Alasan perlu tertulis.

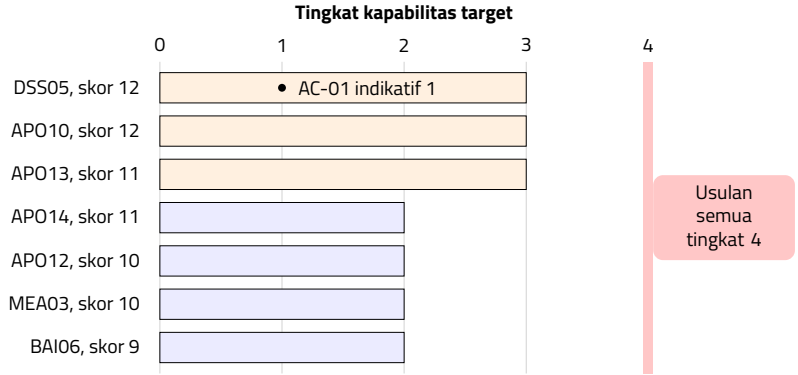
Target Kapabilitas Medikara (Misalkan)

PRADITA University

Objektif	Skor	Bukti C2	Target	Bukti penerimaan
DSS05	12	AC-01 indikatif 1, satu rumah sakit	3	Satu prosedur di 5 rumah sakit
APO10	12	Perjanjian 6 dari 11 butir	3	11 dari 11 butir; latihan laporan 12 jam
APO13	11	SoA 87 diperlukan, 6 dikecualikan	3	Kebijakan dan SoA ditinjau berkala
APO14	11	2.400 dari 96.000 data tidak cocok	2	Definisi punya pemilik
APO12	10	12 skenario berpemilik	2	12 skenario ditinjau tiap triwulan
MEA03	10	7 dari 16 belum diverifikasi	2	16 dari 16 baris terverifikasi
BAI06	9	8 dari 10 tiket lengkap	2	10 dari 10 tiket, termasuk darurat

Target sementara sampai penilaian lengkap tersedia. DSS04 menunggu Bab 10, tetapi 144 uji pemulihan tetap berjalan.

Target Bertingkat dan Usulan Tingkat 4



Bulatan: AC-01 pada satu rumah sakit, bukan tingkat DSS05. Biaya per objektif per tahun (pengandaian): tingkat 2 Rp60 juta, tingkat 3 Rp120 juta, tingkat 4 Rp300 juta. Target ditandai sementara sampai penilaian kapabilitas lengkap tersedia.

Kasus Medikara: Usulan Tingkat 4 untuk Semua

PRADITA University

- Misalkan biaya per objektif per tahun: tingkat 2 Rp60 juta, tingkat 3 Rp120 juta, tingkat 4 Rp300 juta.
- Semua tingkat 4: Rp2,1 miliar. Rancangan awal bertingkat: Rp600 juta, selisih Rp1,5 miliar. Bab 10 menambah DSS04 (T-24), sehingga menjadi Rp720 juta.
- DSS05 naik ke tingkat 4 menambah Rp180 juta, padahal sisa harapan kerugian R-01 hanya Rp25 juta.
- R-05 sebaliknya: peluang 10 persen melewati batas 2 persen, sehingga Paket B tidak dipangkas.
- Rupiah bukan satu-satunya ukuran. Keselamatan dan hak pasien tetap dipertimbangkan.

Profil Target NIST CSF

- Profil target menyebut hasil yang dipilih dan diprioritaskan, serta perubahan yang diperkirakan.
- Bab 6 menyerahkan 14 dari 106 subkategori. Bab ini menambah GV.PO-01 dan GV.PO-02, menjadi 16.
- Analogi: dokter menetapkan sasaran berbeda untuk gula darah, kolesterol, dan tekanan darah.
- Pada 14 baris: terbukti 1 menjadi 11; sebagian 10 menjadi 2; belum ada bukti 2 menjadi 0.
- Profil target dapat menyatakan persyaratan kepada pemasok, misalnya laporan 12 jam.

Profil Target: Govern dan Identify (Misalkan)

PRADITA University

Subkategori	Saat ini	Target	Bukti penerimaan	Paket
GV.OC-03	Sebagian	Terbukti	16 dari 16 baris register terverifikasi	Umum
GV.RM-02	Sebagian	Terbukti	Batas diuji dengan satu penyimpangan	Umum
GV.RR-02	Sebagian	Terbukti	Mandat dan RACI disahkan; 120 akun berpemilik	A
GV.SC-07	Sebagian	Terbukti	Tinjauan vendor berkala; 11 dari 11 butir	A, C
GV.PO-01	Belum dinilai	Terbukti	KB-01 dan KB-05 disahkan serta disosialisasikan	Umum
GV.PO-02	Belum dinilai	Terbukti	8 dari 8 dokumen ditinjau sesuai jadwal	Umum
ID.AM-02	Sebagian	Sebagian	Rekonsiliasi berjalan pada 2 dari 5 rumah sakit	Gel. 2

Profil Target: Protect sampai Recover (Misalkan)

PRADITA University

Subkategori	Saat ini	Target	Bukti penerimaan	Paket
PR.AA-01	Sebagian	Sebagian	Nol akun bersama pada sampel 2 rumah sakit	Gel. 2
PR.AA-03	Sebagian	Terbukti	MFA pada 120 dari 120 akun	A
PR.AA-05	Sebagian	Terbukti	120 dari 120 akun cocok; 60 dari 60 catatan	A
PR.AA-06	Tidak relevan	Tidak relevan	Ditinjau bila vendor hadir di lokasi	Umum
PR.PS-04	Terbukti	Terbukti	Cakupan ditambah Medikara+; catatan rinci 90 hari	D
PR.DS-11	Sebagian	Terbukti	Cadangan disertai hasil uji pemulihan	B
DE.CM-03	Sebagian	Terbukti	247 dari 260 tinjauan mingguan	D
RS.MA-01	Belum ada bukti	Terbukti	2 latihan bersama; laporan vendor 12 jam	C
RC.RP-03	Belum ada bukti	Terbukti	144 uji per tahun; hasil disahkan	B

Tiga Target yang Tidak Saling Dikonversi

Ukuran	Saat ini	Target
Status lokal PR.AA-05	Sebagian, bukti 1 dari 5 rumah sakit	Terbukti pada 5 rumah sakit
Tier Protect	Tier 2 pada pembacaan pimpinan	Tier 3 pada pembacaan pimpinan
Tingkat kapabilitas DSS05	Indikatif 1 lewat AC-01 pada satu rumah sakit	Tingkat 3 setelah penilaian lengkap

NIST mendorong kenaikan tier bila risiko atau mandat lebih besar, atau bila analisis biaya dan manfaat mendukungnya. Tier 4 memerlukan informasi pemasok hampir waktu nyata, sehingga belum menjadi target tahun pertama.

Forum dan Peran Kunci

- Forum memerlukan mandat, anggota, kuorum, jenis keputusan, eskalasi, dan catatan hasil.
- CISO mengoordinasikan keamanan. Petugas pelindungan data menilai dengan independen.
- Pemilik data menetapkan aturan data. Pemilik layanan menanggung hasil layanan.
- Forum arsitektur memeriksa kesesuaian dengan prinsip arsitektur; rincian pada IT40513.
- Analogi gedung: petugas perawatan memperbaiki lampu, bukan mengubah jalur evakuasi.

Dua Contoh: Persetujuan yang Berputar

PRADITA University

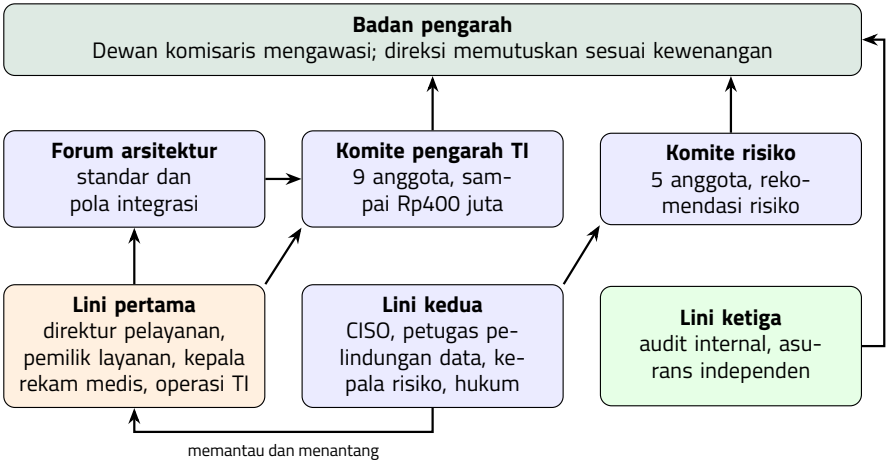
- Misalkan usulan melewati 4 forum bulanan berurutan: paling lama 4 bulan.
- Klaim manual 5 menit: 500 jam atau Rp30 juta per bulan, jadi Rp120 juta selama 4 bulan.
- Alur baru 10 hari kerja, sekitar Rp15 juta. Selisihnya Rp105 juta, dan tinjauan tetap ada.
- Misalkan 40 perubahan per bulan dibawa ke komite: 200 menit, padahal rapat 120 menit.
- Perubahan kecil memakai persetujuan terdelegasi dengan kriteria dan bukti uji.

Rancangan Forum Medikara (Misalkan)

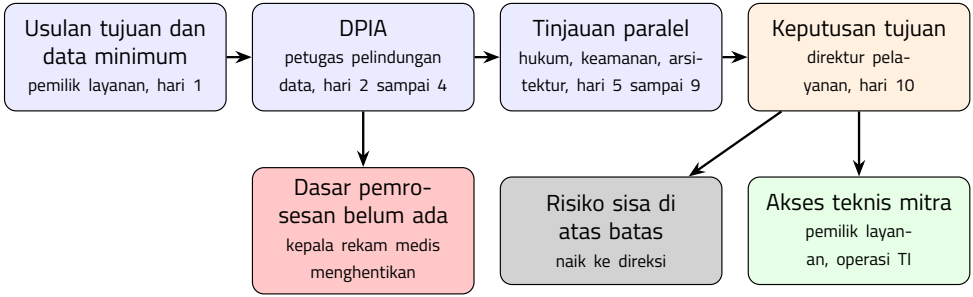
Forum	Mandat	Aturan kerja
Direksi	Risiko di atas batas; keputusan di atas Rp400 juta sampai Rp5 miliar	Laporan triwulan ke dewan komisaris
Komite pengarah TI	Prioritas dan anggaran sampai Rp400 juta	9 anggota, kuorum 6; bulanan 2 jam
Komite risiko	Menelaah risiko di atas batas; rekomendasi ke direksi	5 anggota, kuorum 4; triwulanan 2 jam
Forum arsitektur	Kesesuaian rancangan dan pengecualian standar	6 anggota; dua kali sebulan 1 jam

Biaya forum: 216 + 40 + 144 = 400 jam orang per tahun, sekitar Rp24 juta atau lebih. Yang dinilai adalah kemampuan mengambil keputusan, bukan banyaknya forum.

Forum dan Peran pada Three Lines Model



Kasus Medikara: Alur Pembukaan Data



Direktur pelayanan memutuskan tujuan. Kepala rekam medis memegang hak henti sempit. Risiko sisa di atas batas naik ke direksi.

Kasus Medikara: Dua Pertanyaan C3

- Pembukaan data: direktur pelayanan untuk tujuan, pemilik layanan untuk akses teknis.
- Rekam medis terpadu: direktur pelayanan memegang akuntabilitas, sejalan dengan Bab 2 dan R-11.
- Tinjauan paralel membuat alur 10 hari kerja, bukan 20 hari kerja.
- Empat veto meloloskan 65,6 persen usulan. Satu hak henti sempit meloloskan 90 persen.
- Permenkes 24/2022 Pasal 30: hak akses tetap ditetapkan pimpinan fasilitas pada 36 fasilitas.

Pemisahan Tugas pada AC-01 (Misalkan)

Tugas	Pemegang	Bukti
Mengusulkan	Pengelola vendor	Daftar penugasan dan tanggal berakhir
Menyetujui	Pemilik Medikara+	Persetujuan per akun
Menjalankan	Operasi TI	Tiket pemberian dan pencabutan
Menguji	Audit internal	Hasil uji sampel dan temuan

Klinik dengan 1 administrator memakai pemeriksaan kompensasi oleh peninjau pusat: 18 klinik, 15 menit per bulan, 54 jam per tahun. Potensi konflik dan bukti tinjauan tetap dicatat.

RACI: Satu Accountable per Baris

- RACI: *Responsible, Accountable, Consulted, Informed*.
- *Responsible* mengerjakan. *Accountable* menanggung keputusan akhir.
- Baris “mengelola seluruh data” dengan dua A dipecah menjadi 4 baris yang jelas.
- D-06 pada Bab 2 diputus pemilik Medikara+. Model target menulis satu A, yaitu pemilik layanan.
- RACI bukan pengganti piagam atau hukum. Kolom C bukan hak veto.

Contoh RACI Keputusan Target (Misalkan)

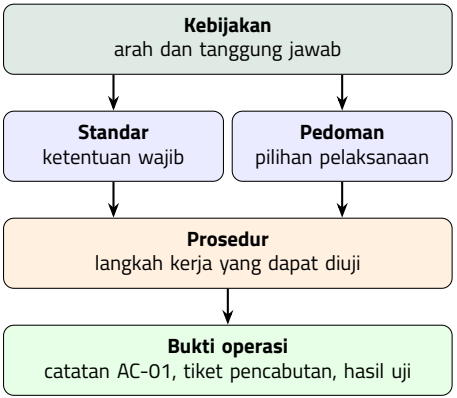
Keputusan	Dir	DP	PL	RM	TI	KA	PD	HK	FA
1. Aturan rekam medis terpadu	I	A	C	R	C	C	C	C	C
2. Tujuan berbagi data mitra	I	A	R	C	I	C	C	C	C
3. Akses teknis mitra	-	I	A	C	R	C	I	I	C
4. Peninjauan akses AC-01	I	I	A	-	R	C	I	-	-
5. Pencabutan akun vendor	-	-	A	-	R	C	I	-	-
6. Perubahan darurat SIMRS	I	C	A	C	R	C	I	-	I
7. Penerimaan risiko di atas batas	A	C	R	C	C	C	C	C	I
8. Uji pemulihan	I	I	A	C	R	C	-	-	I
9. Pemberitahuan insiden data	I	C	C	C	C	R	R	A	-
10. Subprosesor, penghentian vendor	I	C	A	C	R	C	C	C	C

Dir direksi; DP direktur pelayanan; PL pemilik layanan; RM kepala rekam medis; TI operasi TI; KA keamanan (CISO); PD petugas pelindungan data; HK hukum; FA forum arsitektur.

Membaca Matriks sebagai Data

- Huruf A berjumlah 10, dan tiap baris mempunyai tepat satu A.
- Pemilik layanan memegang 6 dari 10 A. Aman bila ada beberapa orang dan pengganti.
- Keamanan menjadi C pada 9 dari 10 baris: 9 kali 4 kali 2 jam = 72 jam per bulan, atau 45 persen.
- Baris 4 dan 5 memakai kriteria tetap: beban turun menjadi 56 jam, atau 35 persen.
- Audit internal tidak masuk matriks, karena lini ketiga menguji dan tidak ikut memutuskan.

Arsitektur Kebijakan



KB-01, KB-05
Disetujui direksi; tinjau 24 bulan

KB-02, KB-06 disetujui komite pengarah TI; KB-04 disetujui direktur pelayanan; tinjau 12 bulan

KB-03, KB-07, KB-08
Disetujui kepala TI atau komite; tinjau 12 bulan

Diperiksa terhadap bukti penerimaan

Standar biasanya wajib. Pedoman dapat dijalankan dengan lebih dari satu cara. Prosedur merinci langkah kerja.

Daftar Kebijakan (Misalkan)

ID	Jenis	Nama dan celah	Pemilik	Penyetuju
KB-01	Kebijakan	Akses dan penggunaan data (G-01, G-04)	Kepala rekam medis	Direksi
KB-02	Standar	Akun vendor (G-01, CP-01)	CISO	Komite pengarah TI
KB-03	Prosedur	AC-01 dan pencabutan (G-01)	Pemilik layanan	Kepala TI
KB-04	Pedoman	Akses darurat klinis (R-05, R-11)	Pimpinan klinis	Direktur pelayanan
KB-05	Kebijakan	Berbagi data dengan mitra (CP-03)	Direktur pelayanan	Direksi
KB-06	Standar	Masa simpan catatan aktivitas (CP-05, G-02)	CISO	Komite pengarah TI
KB-07	Prosedur	Pemberitahuan insiden (CP-04, G-05)	Fungsi hukum	Komite pengarah TI
KB-08	Prosedur	Uji pemulihan (G-03)	Pemilik layanan	Kepala TI

Awalan KB dipakai karena K sudah dipakai register kewajiban Bab 3.

Beban Dokumen dan Pengecualian

- 7 tinjauan per tahun dikali 8 jam = 56 jam. Pelatihan 52 staf dikali 2 jam = 104 jam.
- Jumlahnya 160 jam, atau Rp9,6 juta. Direksi hanya menyetujui 2 dari 8 dokumen.
- Masa simpan 180 hari: ruang simpan 25,7 kali dari 7 hari, dua kali dari 90 hari.
- Pengecualian menyebut cakupan, risiko sisa, kontrol kompensasi, penyetuju, dan kedaluwarsa.
- Bab 5: dari 40 akun-hari menjadi 4 akun-hari dengan batas 24 jam, turun 90 persen.

COBIT dan ITIL 4

PRADITA University

- COBIT memilih hasil dan menilai kapabilitas. ITIL 4 membantu menjalankan layanan.
- Analogi sekolah: pengelola menetapkan hasil belajar, guru menyusun cara mengajar.
- 8 dari 10 tiket lengkap, 2 tiket darurat tanpa analisis dampak: satu bukti, dua kerangka.
- Gangguan 30 menit menyentuh 137 kunjungan dan memakai 25 persen batas 2 jam per bulan.
- ITIL (Version 5) dibangun di atas konsep ITIL 4. Modul ini tetap menyebut ITIL 4.

Pemetaan Pembelajaran COBIT dan ITIL 4

Objektif COBIT	Praktik ITIL 4	Bukti layanan
BAI06 Managed IT changes	Change enablement	Penilaian, otorisasi, uji, rencana pemulihan
DSS02 Managed service requests and incidents	Incident management	Kronologi, pemulihan, komunikasi
DSS03 Managed problems	Problem management	Akar masalah dan perbaikan permanen
APO09 Managed service agreements	Service level management	Target 2 jam per bulan, tinjauan hasil
APO10 Managed vendors	Supplier management	Perjanjian, tinjauan, laporan 12 jam
APO13 Managed security	Information security management	Kebijakan, SoA, hasil tinjauan

Pemetaan ini bukan kesetaraan resmi. Batas 2 jam dari 360 jam layanan setara ketersediaan sekitar 99,44 persen.

Bukti Penerimaan (Misalkan)

Paket	Bukti operasi	Pemeriksa	Bila gagal
A	Catatan AC-01 dan tiket pencabutan	Audit internal	Pemilik Medikara+ menyusun perbaikan
B	Hasil 144 uji pemulihan	Pemilik layanan, lalu audit internal	Uji ulang; R-05 dilaporkan ke direksi
C	Catatan 2 latihan bersama	Petugas pelindungan data	KB-07 diubah; latihan diulang
D	Uji telusur satu rekam; 247 dari 260 tinjauan	CISO	KB-06 ditinjau

Pelatihan 52 staf adalah kegiatan, bukan bukti. 150 pekerjaan cadangan juga bukan bukti pemulihan. Bukti ditetapkan sebelum pekerjaan dimulai.

Kasus Medikara: Menguji Dua Keputusan

PRADITA University

- Simulasi data asuransi selesai hari ke-10, tetapi pendapat DPIA tidak punya tempat pada catatan.
- Simulasi perubahan darurat: pemilik layanan cuti, tidak ada pengganti, menunggu 3 jam.
- Tiga jam melampaui batas 2 jam per bulan, setara 822 kunjungan.
- Perbaikan: pengganti ditunjuk pada baris 6 dan kolom pendapat DPIA ditambah.
- Biaya simulasi hanya 16 jam kerja, atau Rp960.000.

Aktivitas: Peran dan Langkah

PRADITA University

- Pemilik konteks dan analis regulasi merancang struktur serta mandat.
- Analis risiko menyelaraskan target dengan *risk appetite*.
- Analis teknologi memetakan praktik ITIL dan profil keamanan.
- Isi target, forum, RACI 8 sampai 10 baris, dan daftar kebijakan.
- Simulasikan satu alur data mitra dan satu perubahan darurat, lalu perbaiki kebuntuan.

Aktivitas: Luaran, C3, dan Berkas

PRADITA University

- Luaran: struktur, RACI, target kapabilitas, profil target, daftar kebijakan, catatan simulasi.
- Masuk tonggak C3, selaras dengan IT40513, IT40613, dan IT40713.
- Penilaian: celah 30 persen, wewenang 30 persen, kelayakan 25 persen, simulasi 15 persen.
- Berkas: `sources/chapter08/`, dengan daftar pada `README.md`.
- Pendalaman opsional: *policy as code* dengan Open Policy Agent, bersama IT40713.

Ringkasan

- Target berangkat dari celah yang terbukti: 13 celah menjadi empat paket.
- Tingkat tertinggi tidak otomatis tepat: Rp600 juta bertingkat pada rancangan awal, bukan Rp2,1 miliar; Rp720 juta setelah T-24 pada Bab 10.
- Status lokal, tier, dan tingkat kapabilitas tidak saling dikonversi.
- Struktur, RACI, dan kebijakan membuat keputusan dapat dibuat dan dijalankan.
- Bukti penerimaan dan simulasi menutup lingkaran sebelum pasien terkena.

Latihan

PRADITA University

1. Mengapa dalam matriks RACI satu aktivitas hanya boleh memiliki satu pihak *Accountable*? Berikan contoh masalah bila aturan ini dilanggar.
2. Jelaskan perbedaan peran COBIT dan ITIL 4 dengan contoh proses manajemen perubahan di rumah sakit.
3. Sebuah tim menetapkan target kapabilitas tingkat 4 untuk semua objektif. Kritisi keputusan ini dari sisi biaya dan *risk appetite*.

Bacaan dan Pesan Utama

COBIT 2019
NIST CSF 2.0
NIST SP 800-12 Rev. 1
ITIL

- Tata kelola target berhasil ketika organisasi dapat memutuskan, menjalankan, dan meninjau hasil secara konsisten, bukan ketika struktur dan dokumennya terlihat lengkap.